
SentryMesh

A security and governance layer for enterprise AI. Routing, auditing,
and data minimization between applications and LLMs.

The problem: powerful models, weak controls

Direct application-to-LLM connections create critical enterprise gaps.



Privacy & PII Leaks

Sensitive customer data (PII, financial records, legal context) is sent directly to cloud providers without inspection or minimization.



Compliance Gaps

Regulated industries lack deterministic evidence of why specific data was shared, making "AI Governance by Design" impossible to prove.

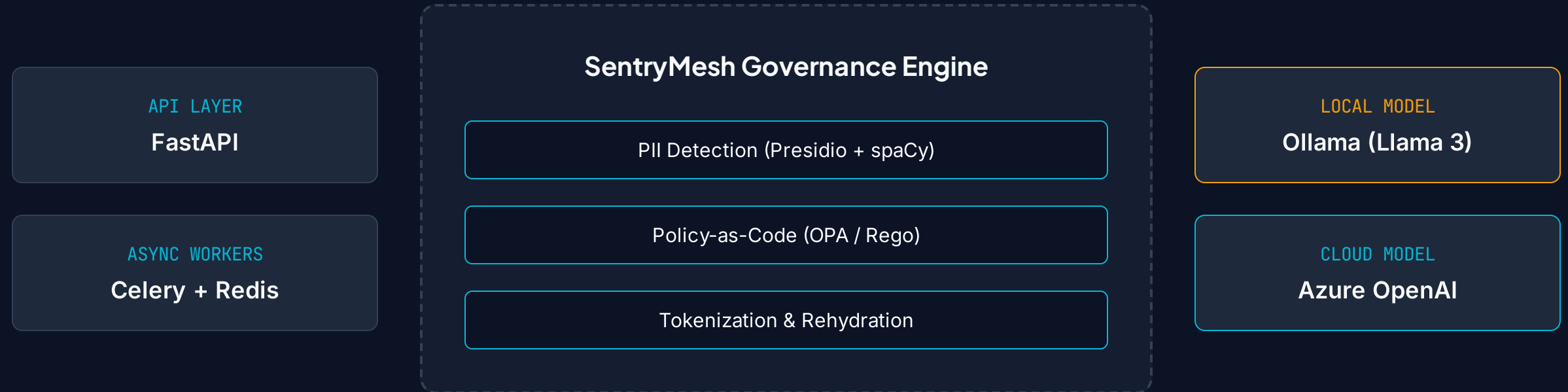


Audit Blindness

Decision-making logic is often hardcoded or hidden in prompts, leaving no auditable trail for security teams or regulators.

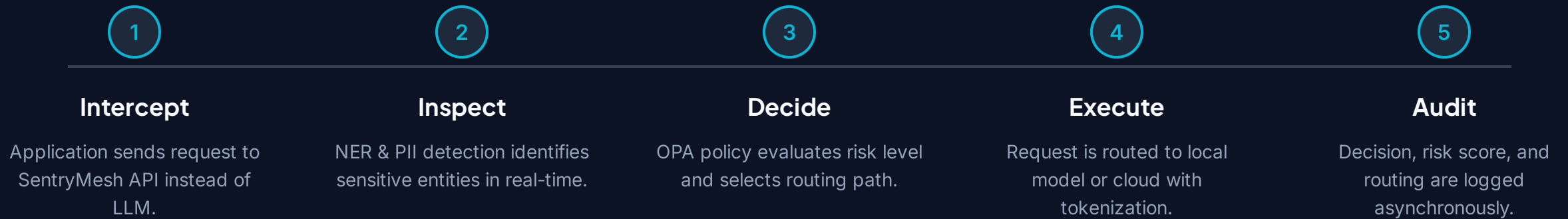
Architecture at a glance

A decoupled governance layer built for scale and auditability.



One request, one explainable decision

Tracing the lifecycle of a secure LLM interaction.



Risk-based routing, not one-size-fits-all

Dynamic path selection based on real-time data sensitivity.

LOW RISK

Fast Path

- No PII detected
- General knowledge query
- Direct Azure OpenAI route
- Standard audit logging

SENSITIVE

Tokenized Path

- PII detected (Names, IDs)
- Tenant-scoped tokenization
- Local Ollama execution
- Secure rehydration

HIGH RISK

Trusted Path

- Financial/Legal context
- Restricted policy match
- Private execution zone
- Full forensic auditing

The hardest engineering trade-off

Balancing detection accuracy against system latency.

CHALLENGE 01

Detection Precision

Too aggressive blocks legitimate work; too loose defeats governance. I treat PII detection as a signal, falling back to conservative policy on uncertainty.

CHALLENGE 02

Latency vs. Compliance

Inspection adds overhead. I optimized by moving auditing to async Celery workers and using structured extraction to prevent context breakage.

~120ms

Avg. Inspection Overhead

98.4%

PII Detection Recall (Presidio + spaCy)

Why this design over alternatives

Deterministic governance vs. probabilistic self-censorship.

ALTERNATIVE: LLM SELF-CENSORSHIP

Probabilistic & Opaque

Relying on system prompts to block PII is non-deterministic and fails under jailbreaks. There is no auditable "why" behind a refusal.

SENTRYMESH APPROACH

Deterministic & Auditable

Dedicated inspection layer with OPA/Rego provides a versioned, testable policy that regulators can inspect and verify.

ALTERNATIVE: SIMPLE MASKING

Context Destruction

Naive masking often breaks financial or legal logic. SentryMesh uses structured extraction to preserve value-critical fields.

SENTRYMESH APPROACH

Intelligent Minimization

Risk-based routing ensures that only the necessary data reaches the cloud, while sensitive work stays in private execution.